DualMS 2.0 Takes the Hint: Zero-Signing-Query Forgeries from Hint Slack

Martin Feussner
Selmer Center, University of Bergen
martin.feussner@uib.no

16 October 2026

This audit used the OpenAI model Daybreak Blue at the ultra reasoning level. OpenAI Codex generated and selected this paper's title and deliberately chose "Takes the Hint" as wordplay on the verifier hint absorbing its reconstruction. OpenAI Codex performed AI-assisted cryptanalysis, implementation, experimentation, review coordination, and technical writing. A separately tasked AI agent performed hostile adversarial review, and a fresh-context AI agent independently reproduced the result from the pinned target and pre-attack evidence. Independent Publication Review returned PASS / NO VETO for the sealed pre-integration candidate (manifest SHA-256 `cd8a152ee60fef056df0c6c08f4f612848ee2007998259149037b698315899a0`). Independent human verification was not performed and is not required. This document reports a verified practical design attack.

Abstract

We analyze the rounded construction in *DualMS 2.0*, IACR ePrint 2026/1941. Its ordinary verifier reconstructs a rounded commitment u, adds a signature hint h, hashes $u + h$, and checks a joint norm on $(z, 2^{\nu_w} h)$. For any aggregate public key and attacker-chosen fresh message, choose a rounded commitment w, query $c = H_{\mathsf{sig}}(w, \mu, aggpk)$, set all response values $z, r, \bar{r}$ to zero, and choose $h = w - u$ for $u = \lfloor -c2^{\nu_b} aggpk \rceil_{\nu_w}$. The verifier reconstructs w exactly, while every response norm except the scaled hint vanishes.

At the advertised 32-signer rounded row, the remaining condition is $\|h\|_2^2 \leq 138330$ for a uniform $h \in R_{31}^7$. A conservative Berry–Esseen calculation gives success probability at least 0.0300039691 per distinct H_{sig} query, expected work at most 33.329 queries, and success probability at least 0.950996 within 99 queries. At the advertised 1,024-signer row, $h \in R_{15}^{10}$ and every canonical hint has $\|h\|_2^2 \leq 125440$, whereas the printed bound permits 329464658. One H_{sig} query therefore suffices for every candidate commitment.

A prospectively sealed primary experiment used exact moduli selected by the paper-linked parameter artifact. A general ordinary verifier accepted fresh-message forgeries at both full rows with zero signing-oracle queries, using 10 and one H_{sig} queries respectively; all retained negative controls rejected. A separate hostile review reconstructed both equations and bounds and returned PASS. A prospectively sealed fresh-context implementation independently accepted both exact rows with zero signing-oracle queries, using four and one H_{sig} queries, respectively. It directly absorbed the complete registration list in H_{agg}, retained the list witnesses, and satisfied all sealed control criteria in 28.16 seconds with 252,432 KiB peak RSS on one worker. The paper supplies no normative final tuple codec, and the author Go artifact uses different NTT-friendly moduli, so the result is a mathematical paper-level random-oracle attack rather than a byte-exact source-conformance claim. The public standard-library reproducer uses a declared direct length-delimited codec. This result is classified as a verified practical design attack.

1 Introduction

DualMS 2.0 is a two-round same-message lattice multisignature that applies modulus rounding to the aggregate public key and aggregate signature to reduce communication [1]. Its advertised rounded rows cover 32 and 1,024 signers and report underlying MSIS and MLWE costs near the 128-bit target. The rounding optimization introduces an explicit hint h: signature aggregation sets h to the difference between the rounded aggregate commitment and a verifier-computable rounded target.

The ordinary verifier does not establish that the hint came from honest aggregation. Instead, it permits the hint to share one Euclidean bound with the Gaussian response z. Setting every response to zero removes all secret and commitment-oracle terms. The attacker can then use the hint to translate the public reconstruction to any selected rounded commitment. The hash challenge is obtained in the usual way by querying the public random oracle on that commitment.

The decisive question is whether the hint fits the printed norm bound. For the 32-signer row it does with constant probability. For the 1,024-signer row the bound is so loose that every canonical hint fits by a factor above 2,600 in squared-norm space. The resulting signatures use zero signing-oracle queries and verify on attacker-chosen messages that have never been signed.

Contribution and originality boundary. We give the exact attack equation, analyze both advertised rounded parameter rows, report a sealed primary full-parameter execution, hostile review, and fresh-context independent reproduction, and provide a self-contained standard-library reproducer. We do not claim that hint absorption or the general need for sound hint bounds is novel. NGCC CS finding sign-07-2 previously used a differently structured free hint to absorb verifier reconstruction terms [4], and an earlier patent expressly warned that reconstruction hints can break soundness if not independently constrained [5]. Neither source analyzes DualMS 2.0 or establishes this result for its two rounded rows.

Status. The profile, primary experiment, hostile-review, fresh-context independent reproduction, final exact-target history, and independent Publication Review gates passed. The result is classified as `VERIFIED_ATTACK`.

2 Target and claim boundary

2.1 Pinned paper and source

The target is Lai, Chen, Liu, Zhao, Wang, and Wang's 39-page *DualMS 2.0: Practical Lattice-Based Two-Round Fiat-Shamir Multi-Signature with Better Efficiency*, IACR ePrint 2026/1941 [1]. The retained PDF has SHA-256

`fdbf743b5108e66efefa686aac92e73f995a2e3e4b94ac27c38c89ead5a26691`.

The official landing page records receipt on 9 September 2026, approval on 12 September 2026, and publication at ACM CCS 2026. The official PDF and version index returned HTTP 403 during the independent profile gate. The retained body matches the official title, authors, abstract, dates, and linked artifact, but we do not claim official byte identity or assign an unsupported version ordinal.

The paper links the author repository `https://github.com/barlogs/DualMS2.0-CCS-sub`. The reviewed source is pinned at commit `227edcd891b93cb9c1d6b42bfc82c4e0b29d18f1`, tree `87febdc8ac7bd4305ac82de8cae02ffd3435585e`. The repository contains the parameter-selection Sage scripts used below, but no final aggregate-key or aggregate-signature codec and no known-answer vector.

2.2 Exact rounded profiles

Let $R = \mathbb{Z}[X]/(X^{256}+1)$. Table 6 prints $\lceil \log_2 q \rceil$, not the integer q. The paper-linked Sage profile and prime-selection routine fix the exact values in Table 1; an independent static profile gate reconstructed both selections.

The Go artifact uses $q = 2113927681$ and $q = 4160727041$, distinct NTT-friendly moduli, while naming the values in Table 1 as the paper moduli. The exact-profile experiments do not substitute the Go moduli for the paper/artifact values.

2.3 Security game

The MS-UF-CMA game gives the adversary public parameters and one honest public key. It permits an output list L^* containing that key and accepts a valid $(L^*, \mu^*, \mathit{AggSig}^*)$ when (L^*, μ^*) was never submitted to the first-round signing oracle. No proof of possession or KeyGen proof is imposed on the

Quantity	32 signers	1,024 signers
(N, m, ℓ)	$(256, 7, 6)$	$(256, 10, 6)$
(η, κ)	$(1, 60)$	$(1, 60)$
q	2113928077	4160748533
(ν_b, ν_w)	$(11, 26)$	$(11, 28)$
$q_b = \lfloor q/2^{\nu_b} \rfloor$	1032191	2031615
$q_w = \lfloor q/2^{\nu_w} \rfloor$	31	15
Aggregate public key (Table 6)	4.38 KiB	6.56 KiB
Aggregate signature (Table 6)	8.86 KiB	11.62 KiB
MSIS / MLWE estimates	128.0/132.6	126.1/127.3 bits

Table 1: The two advertised rounded profiles. Exact moduli come from the paper-linked author artifact because the body prints only their bit lengths.

remaining registered keys. A forgery after zero signing-oracle queries for a list containing the challenge key is therefore a direct game win.

The algebra below works for every aggregate public key, so it does not depend on a specially structured corrupt-key list. The primary 32-signer run used 32 honest KeyGen outputs. The primary 1,024-signer run and public reproducer use one honest challenge key and distinct adversarially registered keys, exactly within the printed game.

3 Rounded verification

Let $A \in R_q^{m \times \ell}$ and let the rounded aggregate public key be $\widetilde{t}_{\nu_b} \in R_{q_b}^m$. An aggregate signature is

$$(c, \widetilde{z}, \widetilde{r}, \widetilde{\boldsymbol{r}}, h) \in \mathcal{C} \times R_q^\ell \times R_q \times R_q^\ell \times R_{q_w}^m,$$

where $\mathcal{C}$ consists of degree-256 polynomials with exactly $\kappa = 60$ coefficients in $\{\pm 1\}$.

Given message μ, the ordinary verifier samples

$$[b, B_{\mathrm{mat}}] = H_{\mathsf{com}}(\widetilde{t}_{\nu_b}, \mu)$$

and computes

$$u = \left\lfloor A\widetilde{z} - c2^{\nu_b}\widetilde{t}_{\nu_b} + \widetilde{r}b + B_{\mathrm{mat}}\widetilde{\boldsymbol{r}} \right\rceil_{\nu_w}, \qquad \widetilde{w}_{\nu_w} = u + h.$$

It accepts precisely when

$$H_{\mathsf{sig}}(\widetilde{w}_{\nu_w}, \mu, \widetilde{t}_{\nu_b}) = c, \tag{1}$$
$$\|(\widetilde{z}, 2^{\nu_w} h)\|_2 \le \mathcal{B}, \tag{2}$$
$$\|\widetilde{r}\|_2 \le \mathcal{B}'_n, \tag{3}$$
$$\|\widetilde{\boldsymbol{r}}\|_2 \le \mathcal{B}''_n. \tag{4}$$

The paper's $\mathcal{B}$ is

$$\mathcal{B} = \sigma\sqrt{2n\ell N} + \sqrt{mN}\left(\sigma\sqrt{2n} + \eta + \kappa 2^{\nu_b - 1} + 2^{\nu_w}\right). \tag{5}$$

The hint has no independent provenance or shortness check. Its only restriction is its contribution to Equation (2).

4 Public-key-only forgery

Theorem 1 (Hint-slack forgery)**.** *Fix any rounded DualMS 2.0 aggregate public key $\widetilde{t}_{\nu_b}$ and any attacker-chosen message μ. For any $w \in R_{q_w}^m$, query*

$$c = H_{\mathsf{sig}}(w, \mu, \widetilde{t}_{\nu_b}),$$

set

$$\widetilde{z} = 0, \qquad \widetilde{r} = 0, \qquad \widetilde{\boldsymbol{r}} = 0,$$

and compute

$$u = \left\lfloor -c2^{\nu_b}\widetilde{t}_{\nu_b} \right\rceil_{\nu_w}, \qquad h = w - u \pmod{q_w}.$$

The resulting aggregate signature passes the hash equation and the two separate response bounds. It is accepted exactly when

$$2^{2\nu_w}\,\|h\|_2^2 \le \mathcal{B}^2.$$

Proof. With all three responses zero, the verifier's $A\widetilde{z}$, $\widetilde{r}b$, and $B_{\mathrm{mat}}\widetilde{\boldsymbol{r}}$ terms vanish. It therefore recomputes the same u as the adversary. Adding $h = w - u$ gives $\widetilde{w}_{\nu_w} = w$, so Equation (1) holds by the adversary's ordinary H_{sig} query. Equations (3) and (4) hold with norm zero. Equation (2) contains only the scaled hint and reduces to the stated inequality. □

The forger never calls either signing oracle and never uses a secret. The message is therefore fresh in the exact game. This is not a zero-total-query attack: the adversary must make the public H_{sig} queries stated below. H_{com} remains part of ordinary verification, but its outputs are multiplied by zero.

4.1 Codec independence

The paper defines the random oracles on bitstrings but does not fix final tuple framing. This prevents a byte-for-byte paper known-answer test. It does not affect the theorem: the forger calls the same public $H_{\mathsf{sig}}(w, \mu, \widetilde{t}_{\nu_b})$ interface as the verifier and copies the returned challenge unchanged. No collision, ambiguous parse, chosen digest, or special challenge value is needed. Any deterministic injective completion of the fixed-shape tuple gives the same attack equation.

5 Concrete analysis

5.1 The 32-signer row

Independent 100-digit arithmetic gives

$$\sigma = 33910694.7761986003223\ldots,$$
$$\mathcal{B} = 24959699776.3818219481\ldots,$$
$$\left\lfloor (\mathcal{B}/2^{26})^2 \right\rfloor = 138330.$$

Lemma 1 (Uniform hint)**.** *In the ideal random-oracle experiment, if the attacker chooses w uniformly from R_{31}^7, then $h = w - u(c)$ is uniform in R_{31}^7 for any fixed aggregate key, where $c = H_{\mathsf{sig}}(w, \mu, aggpk)$ and u is any deterministic function of c and public data.*

Proof. For a uniformly selected w, the ideal random-oracle value c is uniform and independent of w. For every fixed h_0,

$$\Pr[h = h_0] = \sum_c \Pr[c]\Pr[w = h_0 + u(c) \mid c] = \frac{1}{|R_{31}^7|}.$$

Thus h is uniform over the product space. □

There are $7 \cdot 256 = 1792$ independent centered coefficients, each uniform on $\{-15, \ldots, 15\}$. If X is the square of one coefficient, direct summation gives

$$\mathbb{E}[X] = 80, \qquad \mathrm{Var}(X) = 5104, \qquad \mathbb{E}[|X - 80|^3] = \frac{15494144}{31}.$$

The sum has mean 143360 and standard deviation $3024.29628178\ldots$. At threshold 138330, the standardized value without a continuity correction is $-1.66319683\ldots$. The normal cumulative probability is $0.04813652\ldots$, and a Berry–Esseen bound with conservative constant 0.56 contributes error at most $0.01813255\ldots$. Hence

$$\Pr[\|h\|_2^2 \le 138330] \ge 0.0300039691166414.$$

The conservative expected-query upper bound is 33.3289238, and 99 distinct oracle inputs succeed with probability at least

$$1 - (1 - 0.0300039691166414)^{99} \ge 0.9509966510.$$

5.2 The 1,024-signer row

For the larger row, independent arithmetic gives

$$\begin{aligned}\sigma &= 1195768501.04620372663\ldots,\\ \mathcal{B} &= 4872415274260.4413014171\ldots,\\ \left\lfloor(\mathcal{B}/2^{28})^2\right\rfloor &= 329464658.\end{aligned}$$

Here $q_w = 15$, so a canonical centered hint coefficient has magnitude at most 7. Across $10 \cdot 256 = 2560$ coefficients,

$$\max_{h \in R_{15}^{10}} \|h\|_2^2 = 2560 \cdot 7^2 = 125440 < 329464658.$$

Corollary 1. *At the advertised rounded 1,024-signer row, every canonical hint satisfies the joint z/h bound when $z = 0$. One H_{sig} query therefore produces a forgery for every selected rounded commitment.*

The squared-bound ratio is above 2,626. This row needs no hint grind or probability estimate.

6 Experimental evidence

6.1 Primary sealed experiment

The primary implementation was frozen before execution with fixed code, profiles, seeds, messages, controls, candidate caps, success criteria, and resource bounds. It implemented the complete ordinary verifier rather than an attack-specific acceptance test. Static inspection and a later independent checker confirmed every term

$$A\widetilde{z} - c2^{\nu_b}\widetilde{t}_{\nu_b} + \widetilde{r}b + B_{\mathrm{mat}}\widetilde{\boldsymbol{r}},$$

the rounding, challenge, joint norm, and separate response norms.

Measurement	32 signers	1,024 signers
Signing-oracle queries	0	0
H_{sig} queries	10	1
Observed $\|h\|_2^2$	138286	46427
Allowed $\|h\|_2^2$	138330	329464658
Ordinary verifier	accept	accept
Negative controls	8/8 reject	6/6 reject
Wall time	16.02 s	51.48 s
Peak RSS	25,324 KiB	23,040 KiB
Workers	1	1

Table 2: Prospectively sealed primary experiment. These results are separate from the fresh-context reproduction in Table 3.

The 32-signer execution generated 32 distinct honest KeyGen public keys and also accepted a separate constructed signature with nonzero $z, r, \bar{r}$, exercising every ordinary-verifier response term. Its controls changed the message, challenge, each response, hint range, response range, and hint norm.

The 1,024-signer execution used one honest challenge key and 1,023 distinct adversarial registration keys. Its controls changed the message, challenge, each response, and canonical hint range. There is no excessive canonical-hint control at this row because every canonical hint is below the printed bound.

6.2 Hostile review

A separately tasked hostile reviewer did not import or execute the primary runners. It wrote an independent checker that reconstructed both exact moduli, both verifier equations from the stored signatures, the 32-signer Berry–Esseen calculation, and the 1,024-signer maximum-hint inequality. It validated the prospective and post-run manifests and returned `PASS / PRIMARY ATTACK SURVIVES HOSTILE REVIEW`. The reviewer required the codec, source-native, and history limitations retained here.

6.3 Fresh-context independent reproduction

A fresh-context AI agent independently implemented the ring arithmetic, Setup, KeyGen, complete-list KeyAgg, random-oracle interfaces, codecs, ordinary verifier, and forger from the pinned target and pre-attack profile evidence. Before sealing, it did not read the sender intake, primary code, primary outputs, or primary reports. The single prospectively fixed command executed once and returned `PASS_INDEPENDENT_REPRODUCTION_BOTH_ADVERTISED_ROUNDED_ROWS`.

Measurement	32 signers	1,024 signers
Signing-oracle queries	0	0
Attacker H_{sig} queries	4	1
Observed $\|h\|_2^2$	137833	48944
Allowed $\|h\|_2^2$	138330	329464658
Ordinary verifier	accept	accept
Registration keys	32 honest	1 honest + 1,023 adversarial
Full-list witness size	254,078 bytes	11,294,048 bytes

Table 3: Prospectively sealed fresh-context independent reproduction.

Both lists contained distinct keys. Every logical H_{agg} query directly absorbed an injective framing of the complete retained list; no list digest was substituted. The reviewer independently parsed both witnesses and reproduced the first and last direct-input hashes for 32 and 1,024 H_{agg} queries.

Changed-message and valid-challenge-mutation controls rejected at the hash equation. Invalid challenge, hint, and aggregate-key ranges rejected in the codec. An uncompensated nonzero response rejected at the hash equation. A hash-consistent compensated $\bar{r}$ transcript rejected specifically at its independent norm. The 32-signer run retained a hash-consistent oversized hint that rejected specifically at the joint z/h norm; the 1,024-signer run confirmed that the maximum canonical zero-z hint passes the printed bound, as predicted.

The one-worker run took 28.16 seconds and 252,432 KiB peak RSS under a 4 GiB address-space cap. The pre-execution and post-run manifest SHA-256 values are, respectively, `f493f7a434468639b92330878b0896af920e044b474c324da0ed2084072ab7bb` and `a684ab5117043444f2e38ac6b36409010b44041054c325268fd7aaf80c0085cb`. The sealed verdict SHA-256 is `f624f7f7c8ad10097db96bece708c2c95c0bd6ccda6eb17acef7d142bf8c5842`.

6.4 Public reproducer

The accompanying Python package uses only the standard library and one worker. It generates a fresh public matrix and one honest challenge key, constructs the remaining registered keys, runs ordinary KeyAgg, forges an attacker-chosen never-signed message, and invokes a general ordinary verifier. It additionally tests a changed registration list.

Unlike the primary 1,024-signer runner's non-normative list prehash, the publication reproducer absorbs an injective length-delimited encoding of the complete list directly into its declared H_{agg} completion. This removes an avoidable transcript-fidelity qualification. It remains a non-normative codec, because the paper publishes none.

Local package self-tests are supplemental package validation and are not counted as another independent-reproduction trial. The sealed fresh-context evidence above remains the independent gate result.

6.5 Author source control

An optional frozen Go control stopped before compilation because Go attempted to create its module cache under a read-only home path. It neither loaded nor executed the author verifier. We therefore make no claim that an author executable accepted the forgery. This does not alter the exact-paper-profile mathematical result, but it is a preserved implementation limitation.

7 Related technique and history

We located no previous public attack against DualMS 2.0, including either advertised rounded Table-6 profile (n=32 and n=1024), in searches completed on 16 October 2026. The closest earlier public analogue we located is NGCC CS finding sign-07-2, where a differently structured verifier permits a hint to absorb reconstruction terms; our result targets DualMS 2.0's printed verifier and parameter bounds and does not rely on CS's challenge-sign blindness or support grind. We make no claim that the general hint-absorption technique is novel.

The sealed final-history recheck covered exact-title, alias, identifier, general-web, official ACM/ePrint, author/repository, GitHub issue, pull-request, advisory, commit, forum, and scholarly-index checks. It returned `PASS / NO_PRIOR_PUBLIC_EXACT_TARGET_ATTACK_LOCATED` with mandatory related-technique attribution retained. The target had been approved only 34 days earlier, its conference presentation was still in the future, scholarly indexing was incomplete, and the live-search seal did not retain raw endpoint responses. The result is dated and bounded and cannot exclude private, deleted, unpublished, or unindexed work.

The closest earlier public analogue located is NGCC CS finding sign-07-2, published 21 September 2026 [4]. In CS, challenge-sign blindness and the absence of an independent hint bound permit zero responses and a free hint that absorbs reconstruction terms, followed by a support grind. The reported full-size costs are about $2^{108.08}$, $2^{212.46}$, and $2^{394.18}$; the complete demonstration is scaled. That result is not an attack on DualMS or DualMS 2.0. The present forgeries do not require challenge-sign blindness or a support grind, but the shared hint-absorption theme requires attribution.

The Del Pino–Prest patent EP4224785A1, with priority 3 February 2022 and publication 9 August 2023, describes a verifier reconstruction hint and explicitly warns that such a hint may break soundness, motivating independent shortness checks [5]. It does not analyze the DualMS 2.0 verifier or its concrete bound. Fukumitsu and Hasegawa provide earlier lattice multisignature rounding lineage [3]. We claim no novelty for the general observation that hints require sound constraints.

8 Impact, repair direction, and limitations

The verified result is a direct fresh-message forgery under the ordinary mathematical verifier and exact MS-UF-CMA list condition. It affects both advertised rounded rows at practical work. The result does not recover a signer's long-term secret, and it does not claim an attack on the unrounded appendix construction.

A repair must prevent an attacker-chosen hint from translating an arbitrary public reconstruction into a selected hashed commitment while remaining in the acceptance region. One possible direction is an independently sound hint bound; another is a redesign that proves consistency with an honestly formed commitment. Any change must be analyzed together with correctness, rejection sampling, concrete parameters, and the final serialization. We have not validated a drop-in patch.

The following limitations delimit the result:

- the paper body is hash-pinned and metadata-matched, but official PDF byte identity and a version ordinal are not established;
- exact integer moduli come from the paper-linked artifact because the body gives only bit lengths;
- the Go implementation uses different moduli, and no successful source-native execution is available;
- no normative final tuple, aggregate-key, or aggregate-signature codec or known-answer vector is published;
- the 32-signer probability is an ideal-random-oracle bound, while the 1,024-signer statement is a deterministic bound over canonical hints;
- the final attack-history PASS is dated and bounded.

Acknowledgements

The computations were performed on the Norwegian Research and Education Cloud (NREC), using resources provided by the University of Bergen and the University of Oslo.

References

[1] Q. Lai, C. Chen, F.-H. Liu, T. Zhao, Q. Wang, and Z. Wang, "DualMS 2.0: Practical Lattice-Based Two-Round Fiat-Shamir Multi-Signature with Better Efficiency," IACR Cryptology ePrint Archive, Report 2026/1941, 2026. https://eprint.iacr.org/2026/1941.

[2] Y. Chen, "DualMS: Efficient Lattice-Based Two-Round Multi-Signature with Trapdoor-Free Simulation," IACR Cryptology ePrint Archive, Report 2023/263, 2023. https://eprint.iacr.org/2023/263.

[3] M. Fukumitsu and S. Hasegawa, "A Lattice-Based Provably Secure Multisignature Scheme in Quantum Random Oracle Model," IACR Cryptology ePrint Archive, Report 2021/1000; ProvSec 2020. https://eprint.iacr.org/2021/1000.

[4] NGCC Signature Audit, "CS sign-07-2: Verifier challenge-sign blindness enables universal forgery," 21 September 2026. https://ngcc.dev/reports/sign-07.html#sign-07-2-verifier-challenge-sign-blindness-enables-universal-forgery.

[5] R. Del Pino and T. Prest, "Lattice-Based Cryptographic Digital Signature Scheme Utilising Masking," EP4224785A1, published 9 August 2023, priority 3 February 2022. https://patents.google.com/patent/EP4224785A1/en.